

BC06 — Rapport de synthèse

Gestion de projet, conformité RGPD et KPIs métier

Ce document explique le rôle du bloc 6, comment les deux scripts fonctionnent, et ce que signifient les résultats chiffrés (audit RGPD 6/8 et comparaison économique des seuils 0,50 vs 0,98).

Sommaire

1. Objectif du BC06
2. Place dans le projet (BC01 → BC06)
3. Audit RGPD exécutable
4. KPIs métier et impact financier
5. Lecture pour la soutenance
6. Limites et suite

1. Objectif du BC06

Le BC06 n'entraîne pas un nouveau modèle. Il clôt le projet sur deux questions que le métier et le jury posent toujours : le système est-il conforme (RGPD) ? et quel seuil de décision rapporte le plus (euros) ?

Deux scripts exécutables répondent à ces questions :

- `audit_rgpd.py` — 8 contrôles automatiques sur le schéma réel et les artefacts
- `kpis_metier.py` — impact financier des seuils 0,50 et 0,98 du LightGBM (BC03)

Principe

Comme au BC01 (`quality_checks`), un contrôle est une requête / une mesure, pas une affirmation. L'audit peut (et doit) trouver des non-conformités.

2. Place dans le projet

Bloc	Rôle	Livrable clé
BC01	Socle données	400k txs, DWH, Kafka, Redis
BC02	Comprendre	Déséquilibre, profiling, anomalies
BC03	Modèle supervisé	LightGBM AUC 0,998 + SHAP
BC04	Deep learning	Autoencodeur + LSTM
BC05	Industrialisation	API FastAPI, Docker, CI/CD, drift
BC06	Gouvernance	RGPD + KPIs € + bilan

Sans le BC06, on aurait un bon modèle et une API, mais pas de preuve de conformité ni d'arbitrage économique du seuil — indispensables en contexte bancaire.

3. Audit RGPD exécutable

3.1 Comment ça marche

Le script interroge `information_schema` (schémas `dwh/staging`), vérifie la présence des artefacts SHAP/API, et journalise chaque contrôle dans `ops.audit_conformite`. Les résultats sont aussi exportés dans `outputs/resume_audit_rgpd.json`.

3.2 Résultat : 6/8 conformes

Principe RGPD	Contrôle	Statut
Minimisation (Art. 5.1.c)	Pas de nom/email/IBAN/carte personne physique	OK
Pseudonymisation (Art. 4.5)	<code>client_id</code> = UUID opaque	OK
Sécurité (Art. 32)	Pas de n° de carte / CVV stocké	OK

Principe RGPD	Contrôle	Statut
Explication (Art. 22)	SHAP hors-ligne (BC03) + en ligne (BC05)	OK
Accountability (Art. 5.2)	Journaux ops.log_chargement / controle_qualite	OK
Droits personnes (15-17)	Pas de table identité ↔ pseudonyme	OK
Conservation (Art. 5.1.e)	Politique de purge automatique	KO
Sécurité (Art. 32)	Secrets non commités en clair	KO

Les deux KO sont assumés

1) Aucune purge : les transactions restent indéfiniment (rétention type 5 ans anti-blanchiment à formaliser). 2) Mot de passe de démo fraud_secret dans docker-compose / .env.example — acceptable en local, à externaliser (vault / secrets CI) avant un vrai déploiement.

Faux positif corrigé

Le contrôle « nom » avait signalé dim_agences.nom (nom d'agence, pas de personne). Corrigé en excluant cette table avec justification dans le script — pas en masquant l'alerte.

4. KPIs métier — impact financier

4.1 Méthode

Sur les 80 000 transactions de test du BC03 (même split temporel), on recharge le LightGBM et on compare deux seuils. Hypothèse explicite : une fausse alerte coûte 8 € (vérification analyste). Le montant d'une fraude manquée est le montant réel de la transaction (donnée, pas une hypothèse).

Bénéfice net $\approx$ fraude évitée – coût des fausses alertes.

4.2 Résultats

Indicateur	Seuil 0,50	Seuil 0,98 (opti F1)
Fraude évitée	292 884 €	266 895 €
Fraude manquée	4 355 €	30 344 €
Fausse alertes	$758 \times 8 \text{ €} = 6\,064 \text{ €}$	$122 \times 8 \text{ €} = 976 \text{ €}$
Bénéfice net	286 820 €	265 919 €

Constat central (+20 901 € en faveur du seuil 0,50)

Le seuil qui maximise le F1 (0,98) n'est pas le plus rentable ici. Pourquoi ? Une fraude manquée coûte en moyenne beaucoup plus qu'une fausse alerte à 8 €. Le F1 traite ces deux erreurs comme équivalentes — une banque ne le fait pas.

Conclusion opérationnelle : le « bon » seuil dépend du coût réel de la fausse alerte (à valider avec le métier). Si ce coût monte fortement, l'arbitrage peut revenir vers un seuil plus haut. L'API BC05 expose donc les deux lectures (0,50 et 0,98).

5. Lecture pour la soutenance

- BC06 = gouvernance : conformité mesurée + valeur économique du modèle.
- Audit RGPD 6/8 avec KO documentés = maturité (un audit 8/8 sans manque serait suspect).
- KPIs € : le F1 ne décide pas seul ; le seuil est un arbitrage métier.
- Phrase type : « Le seuil optimisé F1 laisse passer 30 k€ de fraude ; au seuil 0,50 le bénéfice net est supérieur de ~21 k€ sur la période de test. »

6. Limites et suite

Limite	Piste
Pas de purge / rétention	Politique formalisée + job d'archivage
Secrets de démo en clair	Vault / secrets GitHub Actions
Coût FA = hypothèse 8 €	Calibrage avec équipes fraude réelles

Limite	Piste
Données synthétiques	Validation sur jeu externe (ex. Sparkov)

Conclusion

Les six blocs forment une chaîne : données → analyse → modèle → deep learning → API → gouvernance. Le BC06 montre que la performance ML n'est pas la fin du projet : il faut aussi prouver la conformité et chiffrer l'impact métier. C'est ce qui transforme un notebook en démarche professionnelle défendable.

Scripts à relancer

```
python bc06_gestion_projet/scripts/audit_rgpd.py
python bc06_gestion_projet/scripts/kpis_metier.py
```